Google Workspace Cleanup (TO-5027)

[TO-5408] Audit and Restrict OAuth Access for Unapproved 3rd Party Applications

Created: 16/Dec/25 Updated: 13/Jan/26

Due: 16/Jan/26 Resolved: 13/Jan/26

Status:	TICKET RESOLVED
Project:	Technology Operations Board
Components:	None
Fix versions:	None
Parent:	Google Workspace Cleanup

Type:	Maintenance	**Priority:**	High
Reporter:	Matt Ammlung	**Assignee:**	Solounge Bowen
Resolution:	Done	**Votes:**	0
Labels:	None		
Remaining Estimate:	Not Specified		
Time Spent:	Not Specified		
Original estimate:	Not Specified		

Attachments:	image (44).png
Issue links:	**Post-Incident Reviews** reviews ~~TO-5429~~ READ AI RECORDED A MEETING WITHOUT MY... Closed
[Tech Ops] Vendor/ Issue Type:	Incident & Security Management - Audit
[TO] Key Performance Indicator:	Completion and accuracy of records, Data Capture Rate, Data Quality & Safety Improvement, IT
KPI Measure:	Audited & updated 628 applications confirming that 42% needed to be blocked while others set to specific Google scopes
Item URL:	https://docs.google.com/spreadsheets/d/16sFIEev-kEqAFQ9L8Zy1Camqu6uY1whu50Uze8_RwjU/edit?gid=1399652265#gid=1399652265
Request participants:	None

Technical Resource(s):	Ryan Perry (Inactive), Zachary Mchayle

Description

Background: Unrestricted access by third-party applications (via OAuth 2.0) can pose a significant data leakage and security risk. This ticket is to audit all connected third-party apps that have been granted access to Google Workspace data, evaluate their necessity and risk profile, and enforce a policy to block or limit access for unapproved applications.

- **Audit:** Generate a report of all third-party apps with data access (via API controls).
- **Review:** Categorize apps as **Trusted** (approved), **Limited** (restricted access), **Specific Google Data**, or **Blocked**.
- **Define Policy:** Define which OAuth scopes (permissions) are deemed high-risk and enforce a block on any unapproved apps attempting to request them.
- **Implement:** Apply the policy to the organization, revoking tokens for blocked applications.

Tier 1: The Company-Wide Announcement (The "Why")

Send a general email to the whole company explaining that an IT security audit was recently completed to ensure data protection and compliance (e.g., SOC2 or HIPAA).

- **The Message:** Briefly explain that unused or unvetted applications will be removed to reduce the company's "attack surface".
- **The Benefit:** Frame it as a way to simplify their digital workspace and protect sensitive company data.
- **The Call to Action:** Tell them that if they find an app they need has been blocked, there is a clear process to request it back.

Tier 2: Personalized Outreach for "High-Impact" Apps

For the **68 apps** used by 10 or more people, do not block them immediately.

- **Action:** Reach out to the specific teams or "power users" of these apps first.
- **Goal:** Confirm if the app is critical for a business process before you change its access level.

Tier 3: Silent Cleanup for "Low-Usage" Apps

For the hundreds of apps with **0 or 1 users** (especially those used by former employees), you can move them to **Blocked** or **Limited** without a specific targeted email for each one.

- **Reasoning:** Since usage is so low, a mass email listing all 500+ apps would cause "app fatigue" and likely be ignored.

- **Safety Net:** Use "remediation messages" in your admin console. If that one person tries to log in, they will see a custom message: *"This app has been restricted for security. Please contact IT if this is a business necessity"*.

Blocker/Risk

- Even when Blocking permissions from app access you have to consider that existing users will still be able to access app
- Tech Ops will need to create documentation on how to remove extensions from their Google Account

References

https://docs.google.com/spreadsheets/d/16sFIEev-kEqAFQ9L8Zy1Camqu6uY1whu50Uze8_RwjU/edit?gid=1399652265#gid=1399652265

https://docs.google.com/spreadsheets/d/1yJEYB9B8The8rO4RyUZTmnfD0QlmovgjVQQGCUag_Os/edit?gid=1462809252#gid=1462809252

https://support.google.com/a/answer/16484119?hl=en&ref_topic=10021546&sjid=823129980897130298-NC

https://support.google.com/a/answer/12653991?hl=en&visit_id=639017845005467420-3139416639&p=apps-bulk-upload&rd=1#zippy=%2Cstep-enter-app-information-save-the-file

Where to locate this within Google WS

- Security → API Controls → Manage App Access → View list of current access apps

Communication that will sent out to users

Subject: Important Security Update: Google Workspace Application Audit

Hi Kindbody Teams,

To ensure Kindbody continues to meet the highest standards for patient data privacy and cybersecurity, our IT team is conducting a comprehensive audit of all third-party applications connected to our Google Workspace.

What is changing? Beginning in the New Year, we will move toward a "Least Privilege" model for our digital tools in a phased rollout. This initiative is scheduled to be completed by **January 16th**.

This transition involves the following:

- **Approved Business Tools:** Essential apps like Atlassian and Slack will remain fully functional.
- **AI & Security Adjustments:** To prevent accidental data exposure, some unvetted AI tools will be restricted. For AI needs, please use our approved tool: **Google Gemini AI**
- **Personal Apps:** Non-business applications (e.g., personal shopping or social apps) will be blocked from using company credentials.

Why are we doing this? Connecting personal or unvetted apps to work accounts creates "Shadow IT" risks. By streamlining our app list, we significantly reduce the likelihood of accidental data exposure, protecting both our patients' information and your professional identity.

What if I need an app that is blocked? We understand that some workflows are unique. If you find an app you require for business is restricted, you can submit a formal **Access Request** directly through the "Access Blocked" screen that appears when you try to log in.

Thank you for your partnership in keeping Kindbody secure as we head into the new year.

Best regards,

Technology Operations Team

Comments

Comment by Solounge Bowen [19/Dec/25]

Currently beginning audit, I'll be handling it in phases as there are 597 applications that need to be reviewed & configured.

Phase	Focus	Action
Phase 1	0-5 Users + Not configured	**Bulk Block** (They are likely personal/shadow IT).
Phase 2	6-20 Users + Not configured	**Review** (Send an email to these users asking for the business case).
Phase 3	High User Count + Not Configured	**Configure** (Move from "Unconfigured" to "Limited" or "Trusted").

Comment by Solounge Bowen [19/Dec/25]

Update

- I noticed **334 of 566** the applications fell under being used by **0-1 users** and not configured
- I went further and categorized the apps by their functions
  - ***Productivity & Communication***
  - ***Document Management & PDF***
  - ***Marketing, Sales & Web***
  - ***AI & Specialized Tech***
  - ***Consumer, Events & Travel***
  - ***Utilities & Tools***
  - ***Health & Wellness***
- Set my recommended Access level for the 334 applications , will work on the remaining 232 after the first review
- Scheduled a meeting with Matt for his thoughts on my approach

Comment by Solounge Bowen [19/Dec/25]

I looked into the potential blocker and confirmed:

When you block an application in the Google Admin Console, the impact on users who have already granted access is immediate and significant:

- **Revocation of Tokens:** Blocking an app automatically **revokes all existing OAuth 2.0 access and refresh tokens**. These tokens are the "keys" that allow the app to communicate with Google data.
- **Immediate Disruption:** Once the app is blocked, it can no longer access any Google services (like Gmail, Drive, or Calendar). Any attempt by the app to make API calls using the old tokens will result in authorization errors.
- **User Experience:** * **In-App Errors:** Users currently using the app may experience sudden service interruptions or error messages (such as HTTP 400 or 401 errors) as the app's background processes fail to sync data.
    - **Blocked Message:** If a user tries to sign in or re-authorize the app, they will be met with a Google-branded screen stating **"Access blocked"** or "This app is blocked by your administrator".
    - **Request Access Option:** Depending on your domain settings, users may see an option to submit a review request to you, the administrator, if they believe the app is necessary for their work.

What happens if you "Unblock" later?

If you decide to move the app from **Blocked** back to **Trusted** or **Limited**:

- **Re-authorization Required:** Because the previous tokens were permanently revoked, users will **not** automatically regain access.
- **New Consent Flow:** Every user will have to go through the "Sign in with Google" process again and manually grant permissions as if they were installing the app for the first time.

How to Bulk Update the report

https://support.google.com/a/answer/12653991?hl=en&visit_id=639017845005467420-3139416639&p=apps-bulk-upload&rd=1#zippy=%2Cstep-enter-app-information-save-the-file

Comment by Solounge Bowen [22/Dec/25]

Update

- Met with Matt and confirmed the following:
    - All Apps Default should be set between **Specific Google Data or Limited**
    - If the application is *unverified* **and** only used *Google Sign in*, set to **Limited**
    - If the application is unverified, and uses other parts of Google , set to **Specific Google Data**
        - This will prevent breaking of applications for our end users

- I proceeded to categorize the remaining applications based on its function
- Matt pulled a reported and shared the current list of all OAuths (Thank you !)
    - https://docs.google.com/spreadsheets/d/1yJEYB9B8The8rO4RyUZTmnfD0QlmovgjVQQGCUag_Os/edit?gid=1462809252#gid=1462809252

Next Steps

- I will review that report and will update accordingly
    - **10 users + :** Look to see if there are any blocked apps that will need to be prioritized and have to contact users
    - **0-9 : Contact end users via IT communications email about update**
- Once I review the list and compare that final time, I will schedule an email to be sent next week to start fresh

Comment by Solounge Bowen [26/Dec/25]

Update

- I've reviewed the list of applications being used by from **11-749 users**
    - Summed up to 68 applications
        - 6 of 68 were ones that will be Blocked
        - 5 of 68 will be updated to Limited
        - 7 will be updated to **Trusted**
        - 50 of 68 will be updated to Specific Google Data
- For the application being used by **0- 9 users**
    - Summed up to 498 applications
        - 188 of 498 were ones that will be Blocked
        - 89 of 498 will be updated to Limited
        - 14 of 498 will be updated to **Trusted**
        - 207 of 498 will be updated to Specific Google Data

With this information I will proceed to schedule an email to be sent company wide next week **Monday, December 29,2025** .

Comment by Solounge Bowen [02/Jan/26]

Update

I shared my current App status recommendation with Matt and he suggested a few more to be changed to another category category. The bottom below shows the update of the number of apps being updated :

- 257 of 566 will be Blocked
- 71 of 566 will be updated to Limited
- 211 of 566 will be updated to Specific Google Data

- 27 of 566 will be updated to **Trusted**

https://docs.google.com/spreadsheets/d/16sFIEev-kEqAFQ9L8Zy1Camqu6uY1whu50Uze8_RwjU/edit?gid=1399652265#gid=1399652265

I'll proceed to update the **Trusted** and the **Limited** categories using Google's template first and see if any tickets arise for Limited. After confirming I'll have the **Specific** and **Blocked** updated

Comment by Solounge Bowen [05/Jan/26]

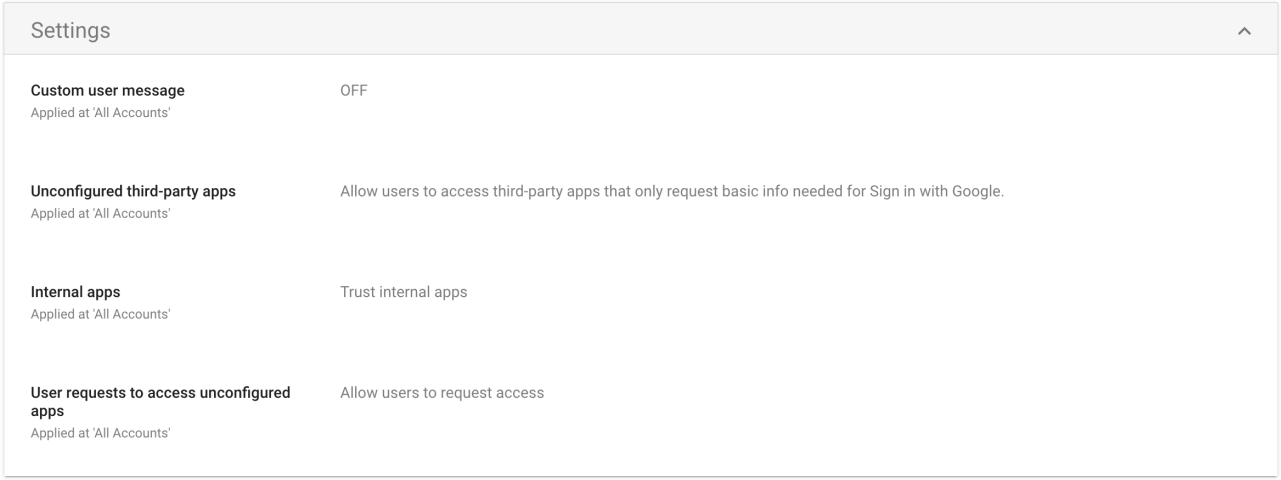
I've confirmed that the following Categories have been updated; **Limited, Blocked, and Trusted.** The Specific Google Data could not be bulk updated therefore I've requested my team to configure the 211 applications manually

Comment by Solounge Bowen [13/Jan/26]

Confirmed that all applications are configured within Google Workspace and the third party app restriction setting can now be updated

Comment by Solounge Bowen [13/Jan/26]

Per confirmation from Matt update the setting



Generated at Wed Apr 08 17:48:34 UTC 2026 by Solounge Bowen using Jira 1001.0.0-SNAPSHOT#100291-rev:3b9a479e32a91e6b609b20067d09b2c03f3d28ef.